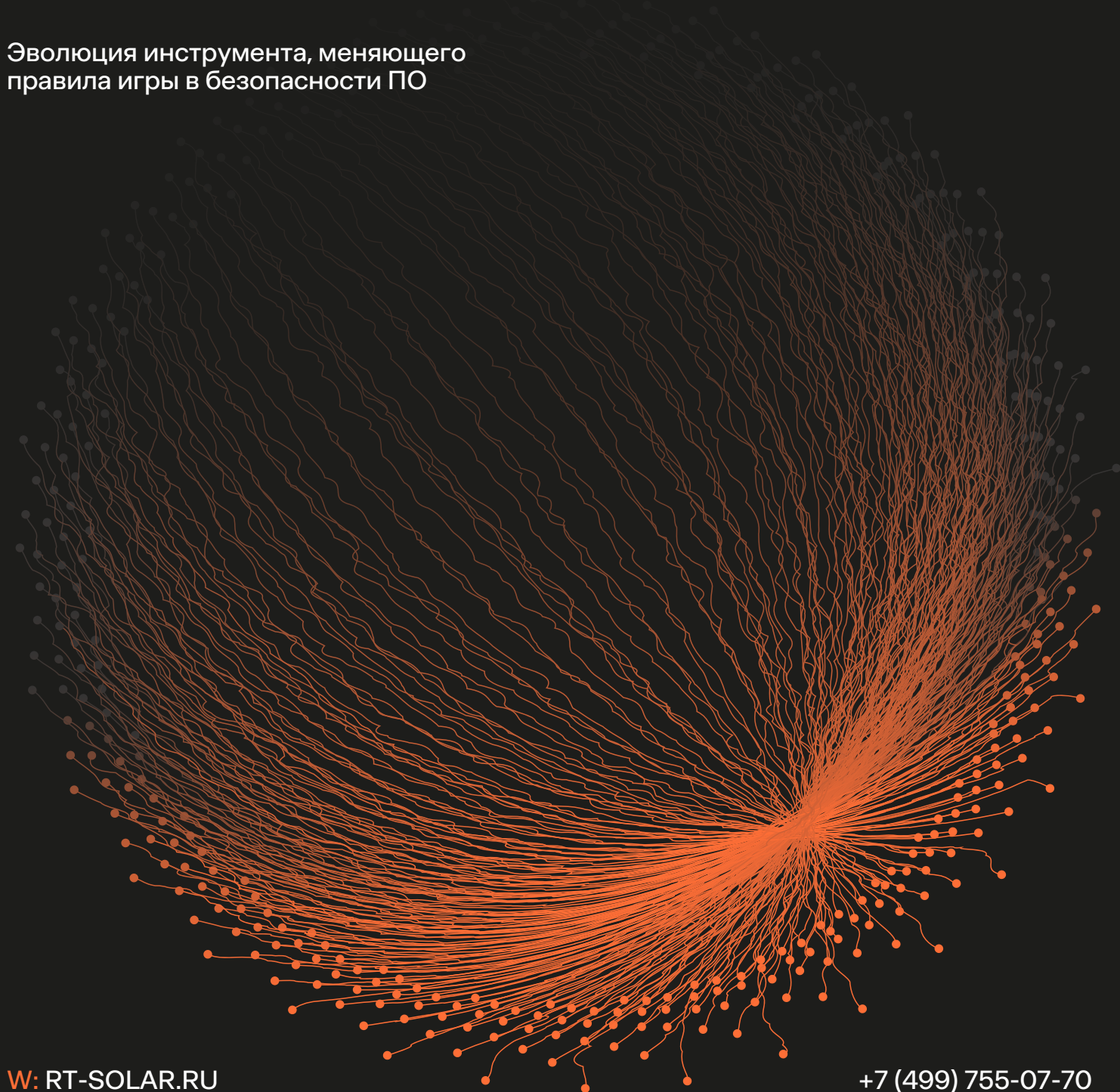


SOLAR APPSCREENER

Эволюция инструмента, меняющего
правила игры в безопасности ПО



Solar appScreener: эволюция инструмента, меняющего правила игры в безопасности ПО

История Solar appScreener началась в одной из российских IT-компаний, в которой тогда работала команда будущих основателей «Солара». Они занимались консалтингом и наблюдали кардинальные изменения на рынке ИБ-технологий, которые послужили основанием для разработки продукта в сегменте Application Security.

<100 МЛРД

Проанализировано строк кода

<10 ТЫС

Проверено приложений и ПО

- К 2014–2015 гг. проблема безопасной разработки приложений не только стала острой и заметной для отраслевого сообщества, но и регулярно привлекала внимание широкой аудитории. Более чем в 75 % реализованных кибератак «успешно» эксплуатировались «дыры» в ПО, которое в то время было самым слабым звеном с точки зрения технической защиты. Например, 15% от всего количества опубликованных уязвимостей приходилось на слабые места платформы Android.
- Громким событием первой половины 2010-х также стал хакерский взлом AppStore, в результате которого в ряд приложений был внедрен вредоносный код XCodeGhost.
- Крупные утечки при взломе российских и иностранных приложений показали, насколько уязвимы привычные пользовательские сервисы, которые и сейчас страдают от тех же самых «болезней»: недостаточного контроля безопасности кода на этапе разработки, недооценки supply-chain-, использования непроверенных библиотек открытого кода.

ТАК ВОЗНИКЛА ИДЕЯ РОССИЙСКОГО APPSEC-ПРОДУКТА: ДЛЯ ОТЕЧЕСТВЕННЫХ КОМПАНИЙ, НА РОДНОМ ЯЗЫКЕ, С ПОНЯТНЫМИ РЕКОМЕНДАЦИЯМИ, ЧЕТКИМ АНАЛИЗОМ И НАУКОЕМКИМИ ТЕХНОЛОГИЯМИ «ПОД КАПОТОМ»

//

Мы наращивали экспертизу на реальных проектах и тогда уже пробовали свои силы, как интегратор, предлагая зарубежные продукты по Application Security нашим заказчикам, проводили десятки кастдевов, чтобы понять, что нужно бизнесу.

Рассказывает автор продукта

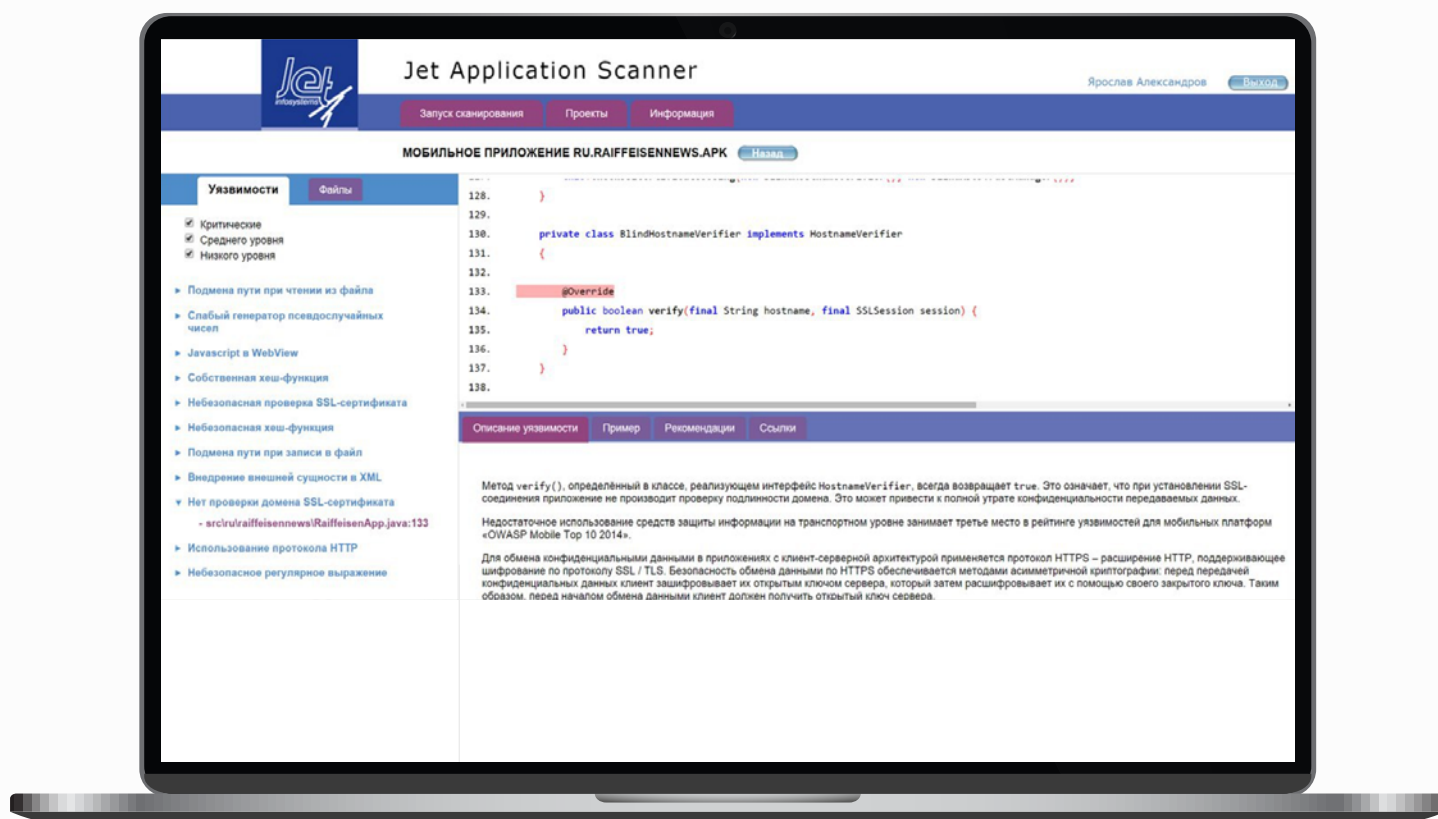
//

2015. Один из первых на борту «Солара», или Как мы с одной идеей решили покорить мир

МЫ ШЛИ СУГУБО ОТ ПРОДАЖ, СТАРАЛИСЬ
СДЕЛАТЬ ИНТЕРЕСНЫЕ РЫНКУ ФИЧИ

На борту у «Солара», который в 2015 году вышел на рынок кибербезопасности как классический стартап, было всего несколько продуктов. В их число вошли разработки в сфере IdM-, DLP-, SWG-систем и будущего Solar appScreener.

Тогда наш продукт назывался Solar inCode. У нас был прототип, небольшой бюджет на разработку и понимание, что российская технология для анализа безопасности приложений будет востребованной. При этом у нас не было гарантии, что, израсходовав выделенный бюджет на разработку в одном квартале, мы найдем деньги на новый этап развития продукта.



Источник: архив ГК «Солар»

Несмотря на скромный бюджет на разработку, уже к октябрю 2015 года команда «Солара» провела первую полноценную демонстрацию Solar inCode для своих клиентов в одном из небоскребов Москвы-Сити

На момент запуска у компании уже были первые продажи и отзывы клиентов, которые были важным аргументом для новых заказчиков.

2012–2015

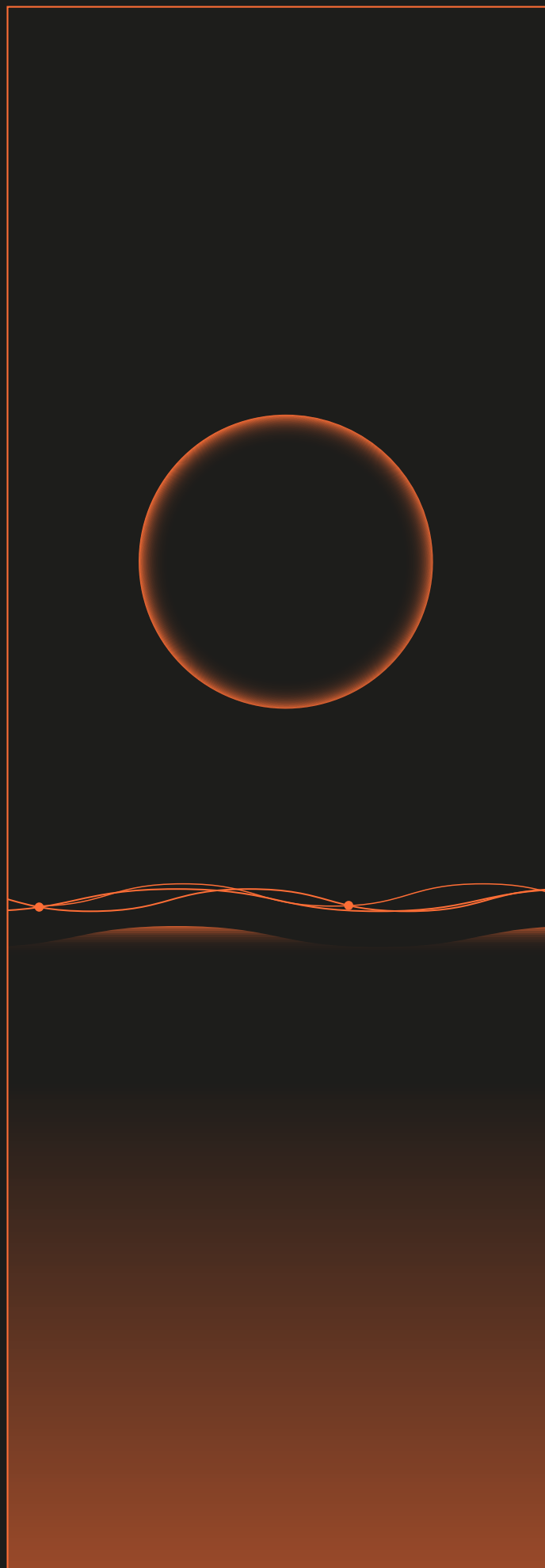
- К 2015 году лидерство иностранных вендоров в сфере анализа кода и безопасной разработки было бесспорным: большую долю рынка занимали решения Fortify (Hewlett-Packard), AppScan (IBM), израильский Checkmarx.
- Российские вендоры тоже пробовали свои силы: с 2012 года существовал сканер PT Application Inspector, InfoWatch инвестировал в разработку похожего продукта.

Solar inCode 1.1.3		Главная панель		Проекты		Информация	
appscan-agent-launcher	gls	Web приложение	—	—	09:38:15	19.11.2015 09:37:53	Запуск сканирования
SAPJavaAgent	gls	Web приложение	—	—	19.11.2015 09:37:17	19.11.2015 09:35:49	Запуск сканирования
MSI_server	gls	Web приложение	—	—	19.11.2015 09:35:02	19.11.2015 09:33:47	Запуск сканирования
MSI_test	gls	Web приложение	—	—	19.11.2015 09:32:42	19.11.2015 09:30:32	Идет сканирование
MSI_sap_com_calend	gls	Web приложение	—	—	19.11.2015 09:29:37	19.11.2015 09:28:37	Идет сканирование
MSI_r1	gls	Web приложение	—	—	19.11.2015 09:22:22	19.11.2015 09:09:51	Идет сканирование
MSI_r12	gls	Web приложение	—	—	19.11.2015 09:00:11		Ошибка сканирования Ошибка работы базы данных Не удалось привести анализ кода
MSI_client2	gls	Web приложение	—	—	19.11.2015 08:40:00	19.11.2015 08:44:07	Сканирование завершено
MSI_client	gls	Web приложение	—	—	19.11.2015 08:41:43	19.11.2015 08:36:54	Сканирование завершено
st_SAS	gls	Web приложение	—	—			Сканирование завершено
st	gls	Web приложение	—	—			Сканирование завершено
gml-test	gls	Web приложение	—	—			Сканирование завершено
zoozhang	gls	Web приложение	31510	4.2 / 5.0			Сканирование завершено
medusa	gls	Web приложение	24670	4.2 / 5.0			Сканирование завершено
coats3d	gls	Web приложение	2981	4.2 / 5.0			Сканирование завершено
ylf	gls	Web приложение	27362	4.6 / 5.0			Сканирование завершено

Источник: архив ГК «Солар», Solar inCode / Solar appScreener 2015

Будущий Solar appScreener
с самого начала оказался буквально
в «красном океане»...

...И ВЫЖИЛ.



2016–2019. Мы выбрали тактику быстрой разработки продукта под задачи клиента

Команда «Солара» сделала ставку на практичность: первыми доступными сценариями стали бинарный анализ мобильных приложений и поддержка ключевых бэкенд-языков (Java, Scala, Kotlin).

Такой подход помог получить первые продажи и референсы в 2015–2016 годах — без «взрывных» маркетинговых вложений, но с быстрым откликом от клиентов.

В это время «Солар» столкнулся с типичными для российского рынка проблемами: нехваткой ресурсов и высокой стоимостью квалифицированных разработчиков, что сужало возможности для быстрого наращивания функциональности продукта.

Команда appScreener пошла своим путем: там, где продукту не хватало поддерживаемых языков или возможностей интеграции, «Солар» предлагал сервисы ручной экспертизы на льготных условиях — чтобы не терять клиентов и одновременно «подпитываться» реальными кейсами.

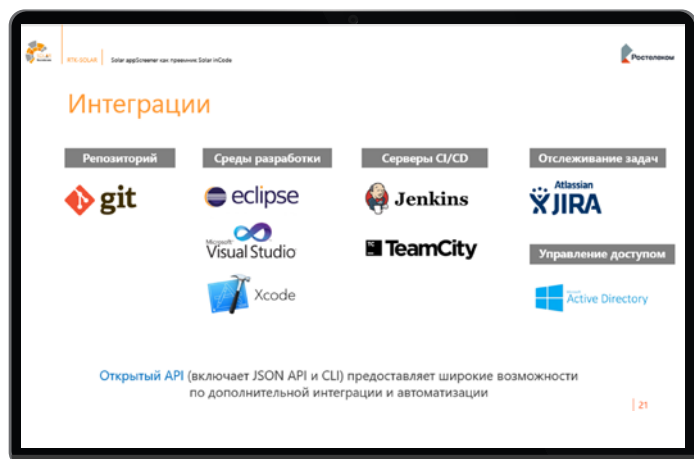


Например, у одного из клиентов был запрос на анализ кода приложений, разработанных на PHP, который наш продукт тогда не поддерживал. Тогда мы предложили ему сервис по анализу исходного кода с большой скидкой, при этом сохранив условия контракта по уже поддерживаемым языкам. Такая тактика позволила нам быстро набрать базу языков, которая закрывала большую часть потребностей компаний.

Рассказывает Владимир Высоцкий, руководитель направления по развитию бизнеса ПО Solar appScreener, который присоединился к команде в 2018 году



Расширение партнерской сети, интеграция продукта с репозиториями, баг-трекерами, CI/CD-серверами



Источник: архив ГК «Солар»

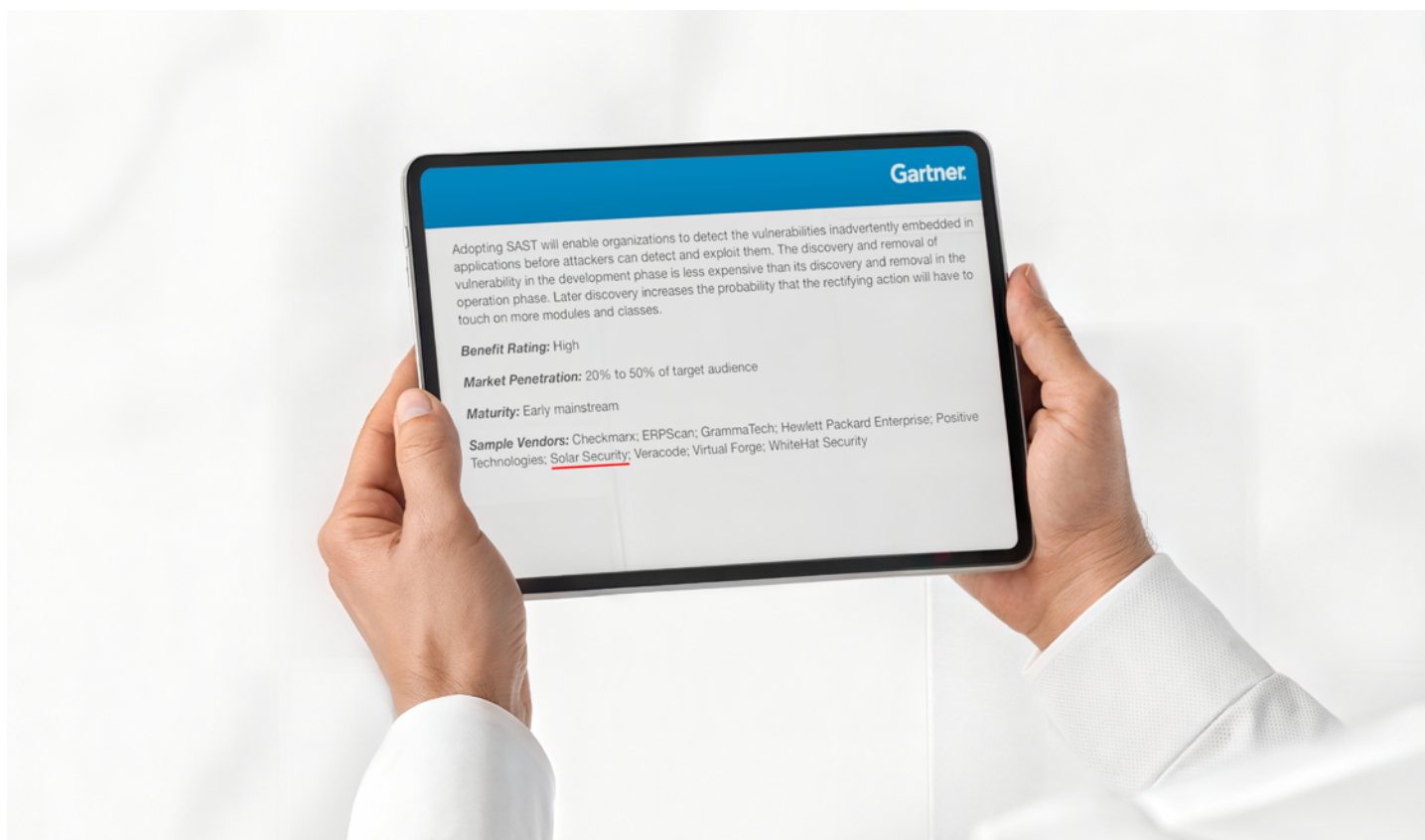
На следующем этапе команда сфокусировалась на расширении партнерской сети, интеграции продукта с репозиториями, баг-трекерами, CI/CD-серверами и тогда же начала свой первый серьезный проект с одним из крупнейших российских ретейлеров.

Анализ кода был лишь частью комплексного проекта, в котором «Солар» создавал под ключ цикл безопасной разработки мобильных приложений, веб-сайтов и приложений для SAP-систем, поддерживающих бизнес-процессы компании.

ЭТОТ ПРОЕКТ ДЛИЛСЯ ПОЧТИ ТРИ ГОДА, НО ПОЗВОЛИЛ ПРИВЕСТИ ВСЕ ПРОЦЕССЫ APPSEC К ЕДИНОМУ СТАНДАРТУ, ПОСТАВИТЬ НА КОНТРОЛЬ И АВТОМАТИЗИРОВАТЬ ПРОЦЕССЫ РАЗРАБОТКИ.

2017

Продукт буквально вошел в «Зал славы» решений для безопасной разработки от Gartner наряду с продуктами Checkmarx, Hewlett Packard и другими грандами рынка.



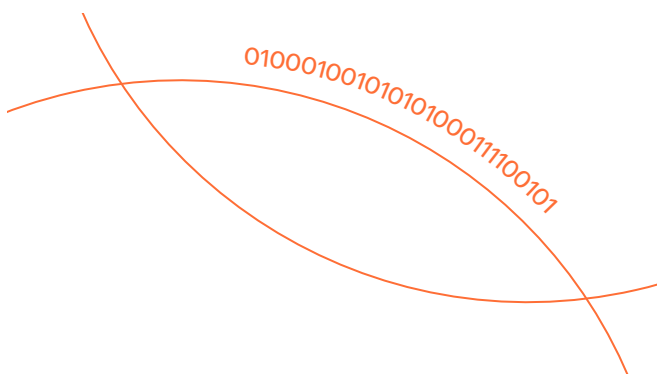
Источник: Gartner, Hype Cycle for Application Security, 2017

2020 – 2022. Мы всегда искали суперход



Первые пять лет развитие продукта зависело исключительно от продаж. И только к 2020 году будущий Solar appScreener вышел на нужные обороты, что позволило нам приступить к новому этапу развития. Цель была амбициозной — рост как минимум X2.

Рассказывает Антон Прокофьев, руководитель отдела операционной поддержки Solar appScreener ГК «Солар», который присоединился к команде летом 2020 года



Модуль SAST (статический анализ кода) к этому моменту был сильной стороной продукта, но только на его основе команда не могла развивать продукт кратными темпами.

Изменился и рынок разработки: вырос спрос на практики безопасной разработки (DevSecOps), с развитием облачных сервисов сформировался запрос на динамический анализ кода и функционал для работы с приложениями, использующими открытый исходный код.

Именно этот «суперход» позволил «Солару» трансформировать сканер приложений в комплексную платформу для проверки безопасности приложений, объединяющую модули SAST, DAST, SCA.

2022

Бывший Solar inCode официально переименован в Solar appScreener.

2023

ВРЕЗ

КОНЕЦ ВРЕЗА

РЕЙТИНГ СТРОИТСЯ НА БАЗЕ
ВОСЬМИ КОНКРЕТНЫХ МЕТРИК

2024

- К 2023 году продукт объединил на базе одного ядра все модули, необходимые для безопасной разработки
- За почти 10 лет развития продукт стал единственным российским анализатором с поддержкой кода, написанного на 36 языках программирования

ABAP, Apex, ASP.NET, COBOL, C#, C/C++, Objective-C, Dart, Delphi, Go, Groovy, HTML5, Java, Java for Android, JavaScript, JSP, Kotlin, LotusScript, Pascal, Perl, PHP, PL/SQL, T/SQL, Python, Ruby, Rust, Scala, Solidity, Swift, TypeScript, VBA, VB.NET, VBScript, Visual Basic 6.0, Vyper, 1C.

Динамический анализ кода (DAST) тестирует веб-приложения, отправляя запросы с заведомо неверными данными и проверяя реакцию приложения на них. Проекты динамического анализа в Solar appScreener можно привязать к проектам статического анализа и на основе корреляции их результатов получить более точную картину безопасности приложения.

Анализ состава ПО (SCA) позволяет выявить зависимости и уязвимости в используемых open-source-библиотеках и снизить риски для разработки приложений. В продукте используются стандартные базы уязвимостей, собственные источники данных «Солара» об актуальных угрозах, направленных на российские компании.

Анализ безопасности цепочки поставок ПО (SCS) позволяет оценить риски, связанные с open source, и сформировать рейтинг безопасности каждого стороннего компонента.

Репутация автора, активность сообщества, внимание к безопасности и др.

Создание модуля анализа OSA, который включил в себя два вида анализа SCA и SCS. Анализ лицензионных рисков помогает отслеживать лицензионные политики при использовании open-source-компонентов, оценивает критичность использования той или иной библиотеки и позволяет избежать юридических рисков, связанных с лицензиями.

2025. Безопасная разработка — необходимость

ЗА 10 ЛЕТ ВЫРОСЛА ЗРЕЛОСТЬ И ПРОДУКТОВ,
И САМИХ КЛИЕНТОВ

Еще 10 лет назад многим клиентам нужно было объяснять, что такое безопасная разработка, зачем она нужна и что происходит, если компания не проверяет код, который пишут разработчики.

Эта ситуация напоминает цикл развития любой технологии — от распространения силами ранних последователей, постепенной поддержки большинством пользователей до момента, когда продукт становится таким же необходимым, как, например, мобильная связь.

<200 КОМПАНИЙ

Уже используют Solar appScreeener.

Среди них банки, ритейлеры, энергетические, транспортные, логистические, IT-компании и др.

//

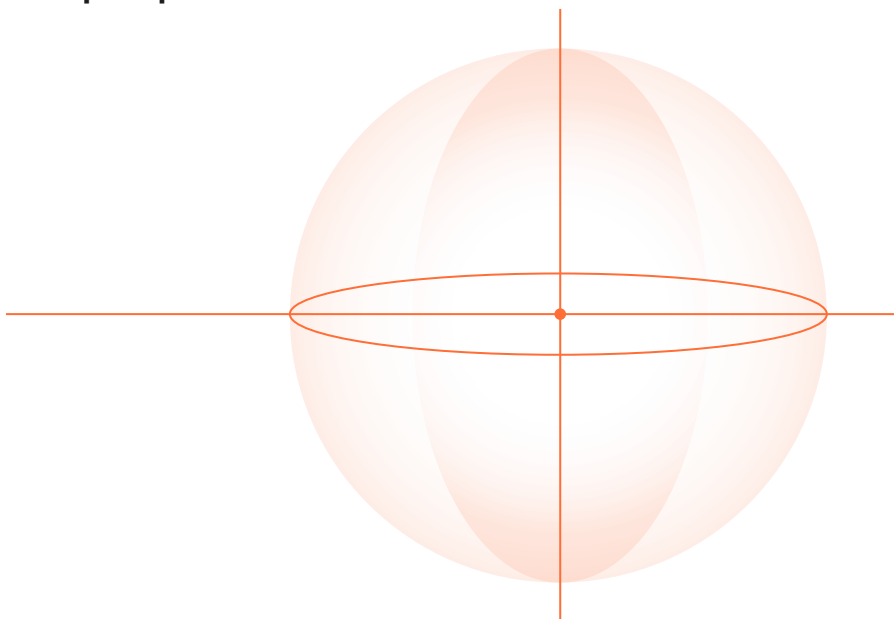
В 2014-2015 гг. стандартным сценарием был ручной анализ кода: руками проверили, посмотрели, написали служебную записку разработчикам на устранение уязвимостей. В 2025 году наша действительность — это автоматизация всех процессов безопасной разработки (DevSecOps), совершенствование технологий анализа приложений, которые разрабатываются на базе открытого исходного кода, и поиск манипуляций в коде, связанных с применением ИИ.

Рассказывает Владимир Высоцкий

//

При этом, как отмечает команда «Солара», есть и второй полюс безопасной разработки

2024



ОСНОВНОЙ ВКЛАД ВНОСЯТ СТАРТАПЫ, КОТОРЫЕ ЗАНИМАЮТСЯ ЗАКАЗНОЙ РАЗРАБОТКОЙ ДЛЯ КРУПНЫХ КОМПАНИЙ

+40%

Рост рынка ПО

+14%

Рост числа компаний

ВАЖНЫМ ДРАЙВЕРОМ ЭТОГО РОСТА СТАЛ ОТКРЫТЫЙ ИСХОДНЫЙ КОД, НО НЕ СТОИТ ЗАБЫВАТЬ О РИСКАХ

79%

Сторонних библиотек не обновляется, нет контроля уязвимостей и регулярно выявляются критические уязвимости (например, Log4j, OpenSSL).

Открытый исходный код уже сейчас используется в софте подавляющего большинства компаний. С помощью опенсорса компании ускоряют выход продукта на рынок и оптимизируют затраты.

С одной стороны, растет скорость разработки, с другой — качество управления зависимостями «опенсорса» остается на очень низком уровне.

//

В 2024 году число уязвимостей в компонентах открытого кода выросло на 98%, при этом число библиотек открытого кода — всего на 25%.

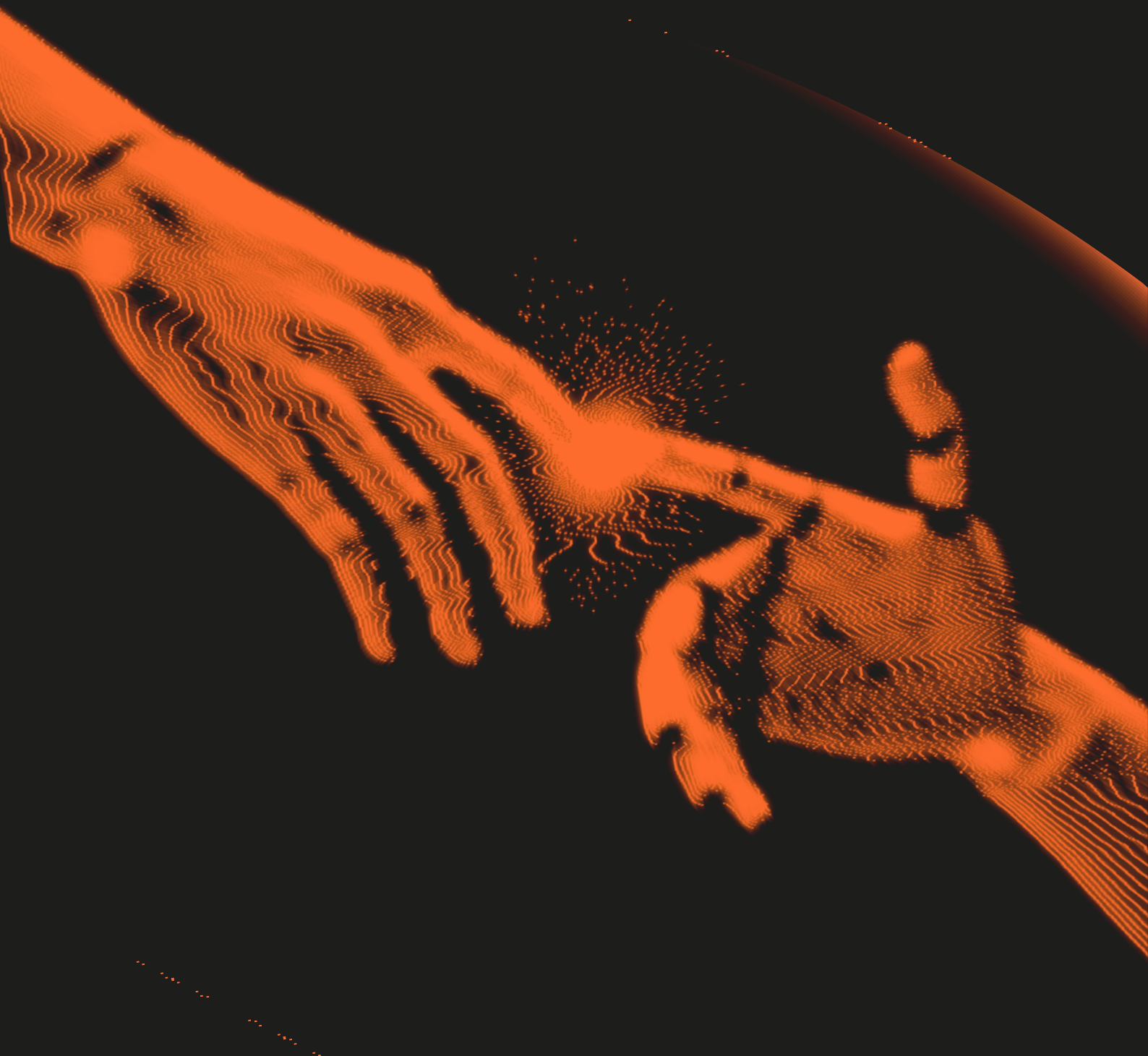
Количество угроз растет в четыре раза быстрее, чем число компонентов для разработки.

Рассказывает Владимир Высоцкий

//

Зрелый рынок задает и новые стандарты безопасной разработки. С появлением оборотных штрафов и новых ГОСТов внедрение практик безопасной разработки — это не только вопрос доверия, но и ответственности перед партнерами и клиентами.

Сейчас в разработке критичных IT-систем, включая решения, требующие обработки персональных данных, финансовые сервисы и продукты в рамках импортозамещения, принимает участие несколько подрядчиков, именно поэтому контроль за безопасностью кода на всем протяжении цепочки поставки ПО становится актуальной задачей для всей IT-индустрии.



2026 год... Что дальше?



Здесь, как в классическом фичере Forbes, команда Solar appScreener могла бы рассказать о планах развития продукта, расширении команды, инвестициях, покорении новых рынков — мы ведь так любим истории про космические корабли.

Но мы хотим поговорить о немного ином будущем...

МГТУ имени Н.Э. Баумана, Новосибирский государственный технический университет, Восточно-Сибирский государственный университет технологий и управления, Казанский национальный исследовательский технологический университет и другие вузы при поддержке «Солара» становятся важными центрами подготовки DevOps- и DevSecOps-инженеров для российского IT-рынка.

Сейчас бесплатными лицензиями для обучения пользуются более 1000 студентов технических специальностей.

Они на практике прокачивают навыки анализа кода мобильных и веб-приложений, компонентов внутреннего ПО.

Доступ к модулю статического анализа (SAST) помогает им выявлять уязвимости и недеklarированные возможности в исходном коде мобильных и веб-приложений на раннем этапе разработки. С помощью модуля динамического анализа (DAST) тестируют отклик веб-приложений на некорректные данные.

С помощью модуля SCA изучают принципы анализа состава ПО (SCA), цепочки поставок (SCS), лицензионных рисков и другие возможности для безопасного использования сторонних компонентов в программных продуктах.

Еще один значимый вклад в развитие будущего со стороны Solar appScreener — это доступные инструменты по безопасной разработке для небольших команд, IT-стартапов, которые пока не могут позволить себе продукты по анализу кода. Их багаж — это open source, небольшой опыт и ограниченность бюджетов. При этом они играют огромную роль в создании приложений, которыми пользуются миллионы клиентов финтех, e-commerce-, медицинских сервисов.

СТОИТ ЛИ ЭКОНОМИТЬ НА ТАКИХ РИСКАХ ДЛЯ ВСЕЙ ОТРАСЛИ?

Для решения этой задачи «Солар» открыл для небольших IT-компаний доступ к модулю анализа сторонних компонентов OSA, который сочетает несколько видов анализа кода.

< 50 небольших компаний уже пользуются новой версией Solar appScreener

[Узнать больше о решении](#)



Мы ориентируемся не только на зрелых профессионалов, но и на новое поколение специалистов по кибербезопасности, которые работают в условиях, кардинально отличающихся от характерных для даже пятилетней давности. Очевидно, что сегодня очень важно учиться реагированию на актуальные угрозы и создавать новые технологии и методы защиты.

За вами — будущее, а мы всегда рядом ♥

Ваш Solar appScreener





T
E

+7 (499) 755-07-70
solar@rt-solar.ru

Центральный офис, 125009,
Москва, Никитский переулок, 7с1